

Security Linter Report

Filename	case7_orm_injection.py
Timestamp	2026-05-22 17:49:20 UTC
Lines of Code (LOC)	16
Verdict	VULNERABLE

ID	Severity	Sink	Source Variable	Source Type	Line
CVE-SL-002	CRITICAL	cursor.execute	query	STDIN	21

CRITICAL	1
WARNING	0
INFO	0
TOTAL	1

CVE-SL-002 — cursor.execute**CRITICAL**

CWE	CWE-89
Sink	cursor.execute
Sink Line	21
Sink Column	9
Sink Expression	result = cursor.execute(query)
Argument	query
Source Variable	query
Source Type	STDIN
Propagation Mechanism	direct assignment from stdin

Taint Path Trace:

Step	Role	Line	Expression
1	SOURCE	9	query = f"SELECT * FROM users WHERE username = '{username}' ...
2	SINK	21	result = cursor.execute(query)

Remediation:

Use a parameterized query and validate the input type. If the value must be an integer, cast it with int():

```
user_id = int(input("ID: "))
query = "SELECT * FROM users WHERE id = ?"
cursor.execute(query, (user_id,))
```

No safe sink paths confirmed.

No sanitization functions detected.

CFG — Total Nodes	11
CFG — Condition/Loop Nodes	0
CFG — Assignment Nodes	6
CFG — Call Nodes	3
CFG — Merge Nodes	0
██	██████████████
DFG — Total Nodes	23
DFG — Total Edges	21
DFG — Source Nodes	3
DFG — Sink Nodes	1
DFG — Operator Nodes	1
DFG — Constant Nodes	4
DFG — Variable Nodes	11
Taint Propagation Hops	11
██	██████████████
Analysis Time (ms)	25.0

Vulnerabilities	1 CRITICAL 0 WARNING 0 INFO
Safe Sinks	0
Analysis Time	25.0 ms
Engine Version	1.0.0
Final Verdict	VULNERABLE